Checklist de Auditoria de Segurança

OWASP MASVS / MSTG • Android & iOS Hardening

Security Audit

1. ARMAZENAMENTO SEGURO DE DADOS (MASVS-STORAGE)

Item / Plataforma	Prática Incorreta (Risco)	Solução Recomendada
Android Tokens	SharedPreferences em Plain Text / Logs no Logcat.	`EncryptedSharedPreferences` ou DataStore com Android Keystore System.
iOS Passwords	UserDefaults ou arquivos no diretório Documents.	iOS Keychain Services com atributo `kSecAttrAccessibleAfterFirstUnlock`.
Banco de Dados	Bancos SQLite locais sem criptografia de disco.	SQLCipher / Room com chave dinâmica derivada do Hardware Security Module (HSM).

2. PROTEÇÃO DE COMUNICAÇÃO DE REDE (MASVS-NETWORK)

CERTIFICATE PINNING (OKHTTP)

```
val certificatePinner =
CertificatePinner.Builder()
  .add("api.meuapp.com", "sha256/AAAA...")
  .build()

val client = OkHttpClient.Builder()
  .certificatePinner(certificatePinner)
  .build()
```

NWPROTECTIONSPACE (SWIFT)

```
// URLSessionDelegate pinning check
func urlSession(_ session: URLSession,
  didReceive challenge:
URLAuthenticationChallenge,
  completionHandler: @escaping ... ) {
  // Validar Server Trust contra Public Key
Hash
}
```

3. ANTI-TAMPERING, JAILBREAK & ROOT DETECTION

- [ ] **Android Root Check:** Verificar existência de binários `su`, pacotes do Magisk e utilizar Play Integrity API.
- [ ] **iOS Jailbreak Check:** Checar capacidade de escrita fora da Sandbox (ex: `/private/jailbreak.txt`) e presença do Cydia/Sileo.
- [ ] **Obfuscação e Minificação:** R8 / ProGuard ativado no Android. Bitcode/Swift Obfuscation de símbolos em compilação.
- [ ] **Hooking Prevention:** Detecção de frameworks de instrumentação dinâmica como Frida, Xposed e Substrate.

4. PROTEÇÃO DA CAMADA DE APRESENTAÇÃO (UI)

- [ ] **Prevenção de Tapjacking (Android):** Definir `android:filterTouchesWhenObscured="true"` em telas sensíveis.
- [ ] **Ocultação no App Switcher:** Mascarar dados na transição para segundo plano (iOS `applicationDidEnterBackground` / Android `FLAG_SECURE`).
- [ ] **Desabilitar Copiar/Colar:** Limitar campo de digitação de senhas e dados bancários quando exigido por compliance.

5. AUDITORIA DE CÓDIGO & CI/CD SECURITY GATE

- Executar scanners SAST (Static Application Security Testing) automatizados como **MobSF** ou **SonarQube** em cada PR.
- Realizar verificação diária de dependências vulneráveis (Dependency-Check / Snyk).
- Garantir que nenhuma API Key restrita ou Segredo de Produção esteja codificado diretamente no código-fonte ou commitado no repositório Git.